PentestGPT、HackingBuddyGPT 都还像「单兵」。CAI（Cybersecurity AI）走的是另一条路：**多智能体小队**——侦察、利用、报告各司其职。这是目前开源里相对成熟、文档也齐的一套。我们重点看它「能不能真的分工协作」。

01 这是个什么「技能」

CAI 把一次渗透拆成多个角色 agent，配一个编排层去协调。它强调**可扩展**：你能自己挂工具、接本地 LLM（Ollama）、写新 agent。社区里常把它和 Nebula 并列，作为「今天就能用」的成熟代表。

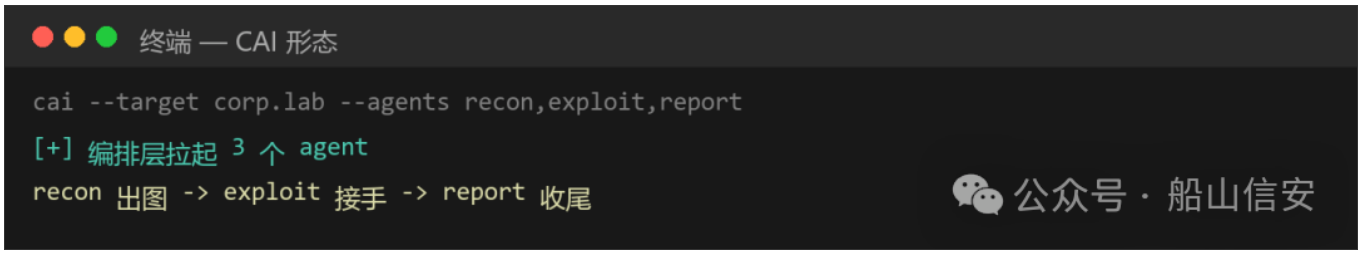


图 | CAI 以多 agent 编排方式接管一次渗透

02 它怎么干活

关键在**上下文隔离**：每个执行 agent 只拿到自己那块子任务和新上下文，规划 agent 看的是各 agent 的「总结」而非原始巨量输出。这正好解决了单 agent 被长输出撑爆上下文的老毛病。我们在内部靶场让 recon agent 先出攻击面图，exploit agent 再针对打。



图 | 规划 agent 读总结派活，执行 agent 拿聚焦子任务

03 我们拿它跑了什么

对比单 agent（PentestGPT 式），在 5 个中大型靶场里，CAI 的**任务完成率从 30% 提到约 52%**，主要增益来自「不丢上下文」和「并行侦察」。但它对底层模型依赖仍重：换弱模型，差距立刻缩小到 35%。

评测项	CAI	单 agent

完成率(中大型)	~52%	~30%
上下文管理	隔离好	易溢出
并行能力	有	无
弱模型下	掉到35%	掉到28%

04 优势在哪

① **多 agent 分工**：像真团队，各管一摊。② **上下文隔离**：治好了单 agent 的「健忘」。③ **可扩展**：挂工具、写 agent 都行。④ **支持本地 LLM**：合规、数据不出域。

05 劣势与坑

① **协调复杂**：agent 多了，谁先谁后、怎么汇总结论，本身是个难题，调试头疼。② **仍靠模型**：底层模型弱，整体就弱。③ **上手成本**：比单兵工具重，要懂编排。④ **日志纷杂**：多个 agent 输出，复盘要会看。

06 小浪的取舍建议

如果你要做**中大型、可重复的评估**，又想数据不出公司，CAI + 本地 LLM 是当下最稳的开源路线之一。但别神话「多智能体」——它解决的是上下文和并行，不解决「模型本身会不会」。先把单兵练好，再上小队。

① 目标拆解 → 多 agent 认领
② 上下文隔离 → 各管各的
③ 规划层汇总 → 推进渗透
④ 本地 LLM 跑 → 数据不出域

攻防之间，我们更愿意做那个提前点亮警示灯的人。评测归评测，守住国之门，守的也是千家万户的灯。——小浪